



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Microsoft EvilTokens Device Code Phishing Threat Daily Update - 2026-09-25

Threat Report

Classification	TLP:CLEAR
Published	2026-09-25
Version	1.0
Author	Lost Boys Cyber
Report Type	Threat Report

TLP:CLEAR | Lost Boys Cyber | Microsoft EvilTokens Device Code Phishing Threat Daily Update - 2026-09-25 - Threat Report

Published: 2026-09-25 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirements
3. Source Review & Confidence
4. Threat Actor / Campaign Overview
5. Tactics, Techniques, and Procedures
6. Infrastructure and Indicators
7. Victimology and Targeting
8. Detection Engineering
 - 8.1. Detection Logic Summary
9. Threat Hunting
 - 9.1. Hunt Hypotheses
10. Risk Assessment
11. Recommended Actions
12. References

Microsoft EvilTokens Device Code Phishing Threat Daily Update - 2026-09-25

> Daily automation refresh: This 2026-09-25 UTC report turns current intelligence coverage into a finished Lost Boys Cyber report with source-backed analysis, structured tables, detections, and hunt content.

> Current-day production note: This report preserves the active priority topic from the prior daily cycle because it remains operationally relevant on 2026-09-25 UTC; the bundle was assigned a new report ID, rebuilt, republished, and uploaded as a current-day artifact rather than reusing stale output.

1. Executive Summary

Microsoft reporting on EvilTokens shows device-code phishing continuing to mature into AI-assisted phishing-as-a-service. Defenders should prioritize device-code flow governance, conditional access controls, token theft monitoring, and finance-team BEC controls.

2. Intelligence Requirements

Requirement	Answered By This Report
What happened or changed?	Current public reporting identifies identity phishing as a defender priority.
Who is exposed?	Organizations with affected workflows, technologies, or sector dependencies described in the source set.
What should defenders do today?	Validate exposure, monitor relevant telemetry, and prepare containment actions.
Confidence	High for source-backed claims; medium for operational extrapolation.

3. Source Review & Confidence

Source	Contribution	Confidence
Microsoft Security Blog	Primary research on EvilTokens and device-code phishing.	High
Microsoft AI-enabled device code campaign	Earlier campaign context.	Medium
Microsoft passkey social engineering	Related identity-social-engineering tradecraft.	Medium

4. Threat Actor / Campaign Overview

This report focuses on defender-relevant activity rather than attribution certainty. Where actor names appear in sources, they should be treated as source-attributed labels unless independently validated by the receiving organization.

5. Tactics, Techniques, and Procedures

TTP	Description	Defensive Relevance
-----	-------------	---------------------

Social engineering / lure delivery	Public reporting emphasizes phishing, recruiter, browser, or topical lures where applicable.	Review email, browser, and identity telemetry together.
Scripted execution	Intrusions commonly progress through command interpreters, script hosts, or staged tooling.	Monitor endpoint process lineage and command lines.
C2 / remote access	Tool staging and outbound control channels are common follow-on patterns.	Correlate DNS, proxy, netflow, and EDR.

6. Infrastructure and Indicators

Observable Type	Observable / Pattern	Handling Guidance
Source-limited public IOCs	No unique atomic indicators were published across all selected sources for this automated report unless listed in iocs.csv.	Treat behavior, tooling, and infrastructure patterns as primary hunt leads.
Domains / infrastructure	Validate from primary source before blocking.	Prefer enrichment and scoped blocking over broad denial lists.
Accounts / identity artifacts	Recruiter, VPN, administrator, SaaS, or service-account themes depending on campaign.	Review conditional access, new devices, impossible travel, and anomalous grants.

7. Victimology and Targeting

Victimology follows the source theme: enterprises exposed to the described campaign, malware-delivery path, or identity-abuse workflow.

8. Detection Engineering

8.1. Detection Logic Summary

Signal	Telemetry Source	Analytic Goal
Unusual script or remote tool launch after web, email, remote access, or SaaS activity	EDR / process telemetry	Identify initial access and execution.
New outbound connections to untrusted infrastructure	DNS/proxy/netflow	Surface command-and-control or tool staging.
Identity anomalies linked to target workflow	Identity provider logs	Detect stolen credential or social-engineering follow-on use.
<pre> title: Suspicious Script Or Remote Tool Activity In Daily Threat Coverage status: experimental description: Detects suspicious script execution and remote-tool staging patterns relevant to daily threat-intelligence coverage. logsource: category: process_creation product: windows detection: selection_parent: ParentImage endswith: - '\chrome.exe' - '\msedge.exe' </pre>		

```

- '\outlook.exe'
- '\teams.exe'
- '\w3wp.exe'
selection_child:
  Image|endswith:
    - '\powershell.exe'
    - '\cmd.exe'
    - '\wscript.exe'
    - '\cscript.exe'
    - '\mshta.exe'
    - '\rundll32.exe'
  condition: selection_parent and selection_child
level: high

DeviceProcessEvents
| where Timestamp > ago(14d)
| where FileName in~
("powershell.exe","cmd.exe","wscript.exe","cscript.exe","mshta.exe","rundll32.exe")
| where InitiatingProcessFileName in~
("chrome.exe","msedge.exe","outlook.exe","teams.exe","winword.exe","excel.exe")
| summarize Events=count(), Commands=make_set(ProcessCommandLine, 20) by DeviceName, FileName,
InitiatingProcessFileName, AccountName
| order by Events desc

DeviceNetworkEvents
| where Timestamp > ago(14d)
| where InitiatingProcessFileName in~
('powershell.exe','cmd.exe','wscript.exe','cscript.exe','rundll32.exe','python.exe','node.exe')
| summarize Connections=count(), RemoteIPs=dcount(RemoteIP), RemoteUrls=make_set(RemoteUrl, 20) by
DeviceName, InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Connections desc

```

9. Threat Hunting

9.1. Hunt Hypotheses

Hypothesis	Query Focus
Initial lure resulted in script or LOLBin execution	Process lineage from browsers, Office, chat, or email clients.
Payload staging used commodity infrastructure	New domains, direct-IP connections, unusual ASNs, or short-lived hosts.
Identity compromise followed social engineering	OAuth grants, device-code flow, MFA changes, impossible travel, and risky sign-ins.
SigninLogs where TimeGenerated > ago(14d) where ResultType != 0 or RiskLevelDuringSignIn in ("medium","high") summarize Signins=count(), Apps=make_set(AppDisplayName, 20), IPs=make_set(IPAddress, 20) by UserPrincipalName, RiskLevelDuringSignIn order by Signins desc	

10. Risk Assessment

Dimension	Assessment	Rationale
Likelihood	Medium to High	Current public reporting and commodity reuse make exposure plausible.
Impact	Medium to High	Identity compromise, malware staging, or sector disruption can create business impact.
Detection Difficulty	Medium	Behavioral telemetry is available, but

		atomic indicators may be sparse.
--	--	----------------------------------

11. Recommended Actions

1. Brief SOC and identity teams on the source-backed behaviors.
2. Run the included process/network/identity hunts for 14-30 days of telemetry.
3. Review exposed third-party and remote-access paths tied to the affected workflow.
4. Convert confirmed local hits into case-specific IOCs and containment tasks.

12. References

- [1] Microsoft Security Blog: <https://www.microsoft.com/en-us/security/blog/2026/09/22/unmasking-eviltokens-getting-to-the-root-of-device-code-phishing/>
- [2] Microsoft AI-enabled device code campaign: <https://www.microsoft.com/en-us/security/blog/2026/04/06/ai-enabled-device-code-phishing-campaign-april-2026/>
- [3] Microsoft passkey social engineering: <https://www.microsoft.com/en-us/security/blog/2026/09/09/passkey-themed-social-engineering-leads-identity-cloud-compromise/>